Meet Your Presenter

M. Shehryar Raza

Visiting Faculty

linkedin.com/in/ms-raza1

Foundations & The Problem Statement

Why is secure communication so hard?

Welcome to the foundations of computer security. In this lecture, we'll explore why protecting digital communication remains one of the most challenging problems in computer science. By understanding the core challenges, you'll gain insight into why security requires constant vigilance and sophisticated solutions.

The Classic Example: Alice and Bob

Meet Alice and Bob, the protagonists of nearly every security story. Alice wants to send a private message to Bob across an insecure network. This simple scenario reveals the fundamental challenges that every secure system must address.

Eavesdropping (Eve)

Eve is an adversary who attempts to secretly listen to the communication between Alice and Bob. Can she intercept and read the message as it travels across the network? This threat targets confidentiality.

Tampering (Mallory)

Mallory is a malicious actor who wants to alter messages in transit. Can she change "Send $10" to "Send $10,000" without detection? This attack compromises message integrity.

Impersonation (Trudy)

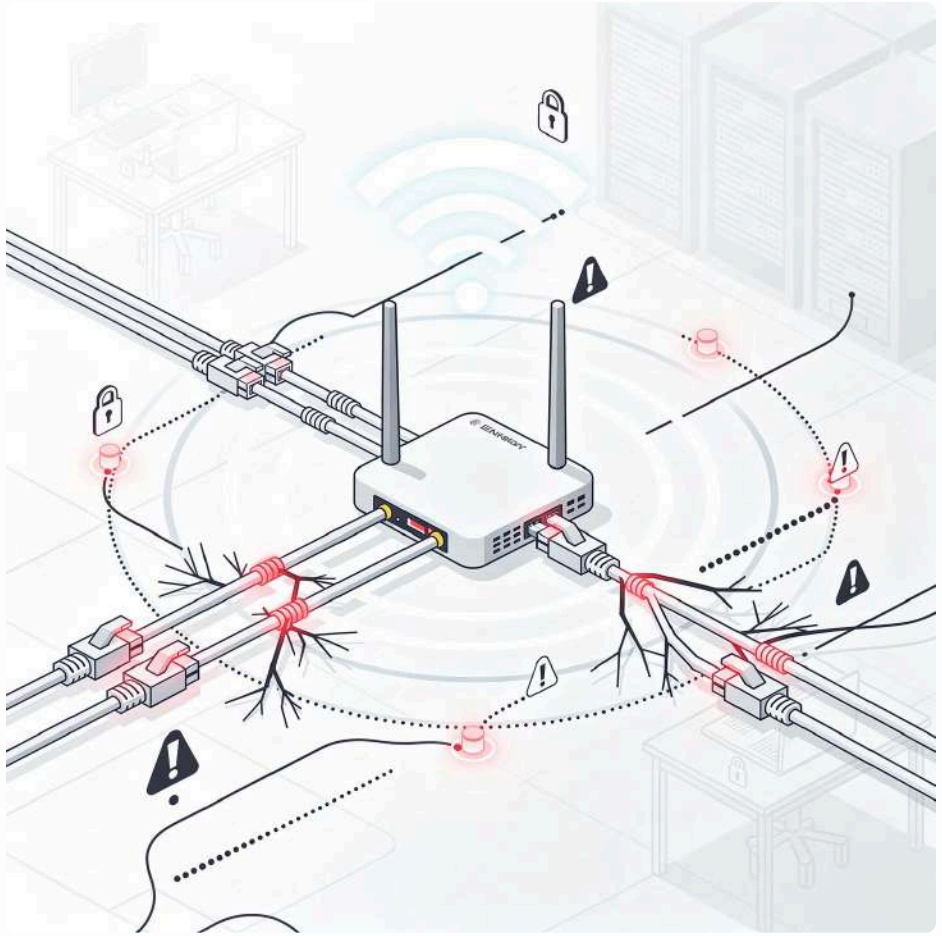
Trudy attempts to masquerade as Alice, sending messages that appear to come from a trusted source. Can Bob verify that messages truly originate from Alice? This challenges authentication.

Denial & Repudiation

After sending a message, Alice might claim she never sent it. Can Bob prove Alice authored the message? This issue affects accountability and non-repudiation in digital communications.

These adversaries and their attacks form the foundation of our security analysis. Throughout this course, we'll examine how cryptography and security protocols defend against each threat.

Why the Channel is Insecure



Inherent Vulnerability

Communication channels—whether the internet, WiFi networks, physical mail, or public spaces—are fundamentally vulnerable to interception and manipulation. Unlike face-to-face conversation, digital communication traverses infrastructure we don't control.

The adversary can position themselves at multiple points: intercepting packets on the wire, compromising endpoints like routers or servers, or acting as an insider with legitimate access. This multi-faceted threat landscape makes securing communication extraordinarily complex.

Understanding that channels are insecure by default is the first principle of security design. We must assume hostile environments and build protection accordingly.

The Core Goals: CIA Triad

The CIA Triad represents the three fundamental objectives of information security. Every security mechanism aims to achieve one or more of these goals. Let's examine each through Alice and Bob's communication:

Confidentiality

Eve shouldn't be able to read the message. Information must remain private and accessible only to authorized parties. Encryption provides confidentiality.

Integrity

Mallory shouldn't be able to alter the message without detection. Data must remain accurate and complete. Cryptographic hashes and digital signatures ensure integrity.

Availability

Bob should receive the message when needed. Systems must remain operational and accessible to legitimate users, even under attack. Redundancy and resilience support availability.

Important Trade-offs: These goals sometimes conflict. Extreme confidentiality measures might impact availability. Strong authentication can reduce usability. Security design requires balancing these objectives based on specific requirements and risk tolerance.

Threat, Vulnerability, and Risk

Understanding the relationship between threats, vulnerabilities, and risk is essential for security analysis. These concepts form the foundation of risk assessment and inform our security decisions.

Threat

A potential danger or adversary. Eve represents the threat of eavesdropping—a capable attacker with motivation to intercept communications.

Vulnerability

A weakness that can be exploited. An unencrypted communication channel is a vulnerability that Eve can exploit to read messages.

Risk

The likelihood and impact of a threat exploiting a vulnerability. Risk measures the actual danger posed by the combination of threats and vulnerabilities.

$$Risk = Threat \times Vulnerability \times Impact$$

This formula guides security investment: reduce risk by mitigating threats, patching vulnerabilities, or minimizing potential impact.

Risk Assessment in Practice

Security professionals use this framework to prioritize defenses. High-value assets with known vulnerabilities facing motivated adversaries receive immediate attention.

Not all risks warrant equal investment—cost-effective security focuses resources where risk is greatest.

The Solutions & Principles

How do we protect Alice, Bob, and their message?

Having established the problems, we now turn to solutions. Modern security employs multiple layers of defense, starting with the fundamental question: how does Bob know he's really communicating with Alice?

Identity & Authentication

Before Bob trusts any message, he must verify it truly comes from Alice. Authentication is the process of proving identity—establishing that someone is who they claim to be.

Something You Know

Passwords and passphrases are knowledge-based authentication. Only Alice should know her password, proving her identity when she provides it.

Something You Have

Physical tokens, smart cards, or mobile phones serve as possession-based authentication. Alice proves her identity by demonstrating she has a specific device.

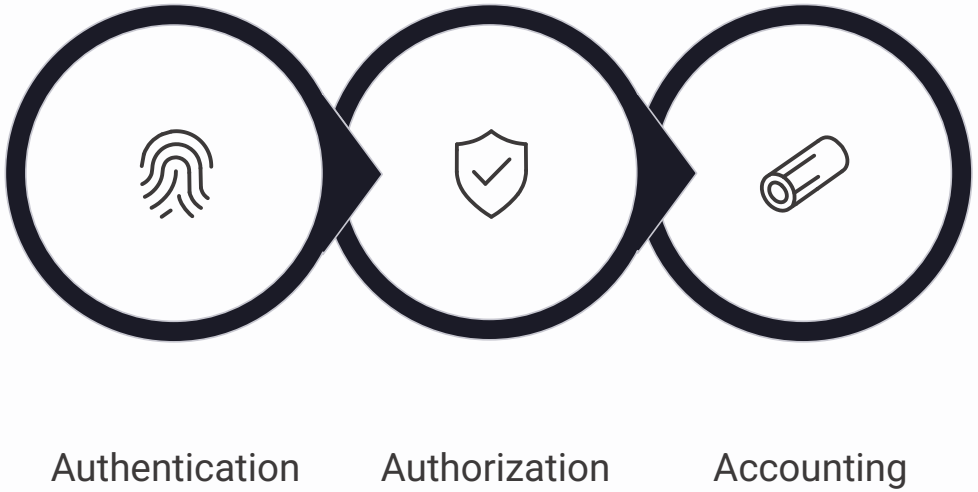
Something You Are

Biometric authentication uses unique physical characteristics—fingerprints, facial features, or iris patterns. These are inherent to Alice and difficult to forge.

Multi-Factor Authentication (MFA): Combining two or more authentication factors dramatically strengthens security. Even if an attacker steals Alice's password, they still need her phone or fingerprint. MFA is now a security best practice for protecting sensitive systems.

Beyond Authentication: The AAA Framework

Authentication alone isn't sufficient for comprehensive security. The AAA framework extends beyond identity verification to encompass authorization and accountability, creating a complete access control system.



This framework ensures complete access control throughout the system lifecycle.

Authentication

Who are you? Authentication verifies identity—confirming that the user is actually Alice. This is the gateway to system access, the first critical checkpoint.

Authorization

What can you do? Once authenticated, authorization determines Alice's permissions. Can she send funds, access files, or modify data? Authorization enforces the principle of least privilege.

Accounting & Auditing

What did you do? Accounting creates detailed logs of Alice's actions—when she logged in, what resources she accessed, what changes she made. These records enable forensic analysis and compliance.

Non-Repudiation

Cryptographic Proof

Digital signatures create unforgeable mathematical proof that Alice authored a specific message. The signature uniquely links Alice's identity to the message content.

This cryptographic binding makes denial practically impossible.

Non-repudiation is the security service that prevents Alice from denying she sent a message. In digital systems, where messages can be easily copied or forwarded, proving authorship becomes critical for legal and business transactions.

Consider e-commerce: when Alice purchases goods online, both parties need proof of the transaction. Alice can't later claim she never ordered the product, and the merchant can't deny receiving payment. Digital signatures provide this mutual assurance.

Non-repudiation directly connects to the accounting function in the AAA framework. Together, they create an auditable trail that establishes accountability for all actions in the system.

Security Principles: Saltzer & Schroeder

Jerome Saltzer and Michael Schroeder established foundational principles that guide secure system design. These timeless guidelines, published in 1975, remain relevant today and help architects avoid common security pitfalls.

Least Privilege

Users should have only the minimum access required for their tasks. Alice should access only what she absolutely needs—nothing more.

Fail-Safe Defaults

Default to "deny access" rather than "allow." Security should be opt-in, not opt-out. Systems should be secure by default.

Economy of Mechanism

Keep security designs simple and small. Complex systems have more vulnerabilities and are harder to verify. Simplicity enables security.

Complete Mediation

Check every access, every time—not just on first use. Never cache authorization decisions indefinitely. Continuous verification maintains security.

Open Design

Security should not depend on design secrecy. The mechanism should remain secure even if adversaries understand how it works—only keys should be secret.

These principles embody decades of security wisdom. Following them significantly improves system security and resilience against attacks.